Custodia: guion de la charla

Dioyanny Aranguren Sanabria y Paula Quintana Barrera · Electiva Específica
17 diapositivas · 11 minutos y 15 segundos, más preguntas

Cómo usar este guion

Cada diapositiva está en su propia página, con una miniatura para reconocerla y cuatro partes:

- **Qué se ve**: lo que aparece en pantalla.
- **Qué significa**: la explicación del tema, para repasarlo aunque se haya olvidado por completo.
- **Qué decir**: el texto para decir en voz alta. No hay que leerlo palabra por palabra; basta con decir las ideas en ese orden.
- **Si preguntan**: respuestas cortas a preguntas probables (solo donde aplica).

Al final hay un glosario con los términos técnicos.

La idea de toda la charla en una frase: en la mayoría de los programas, quien decide si alguien puede abrir un archivo es el propio programa; en Custodia lo decide Windows, y además el archivo está cifrado, se pide un código del teléfono y todo queda registrado.

Las cuatro partes de una charla TED

La charla sigue las cuatro partes que pide el profesor: **apertura** con un caso real y una pregunta (diapositivas 1 a 3), **explicación de la solución** (4 a 12), **demostración del artefacto** (13 y 14) y **cierre con llamado a la acción** (15 y 16). Las diapositivas tienen poco texto a propósito: el detalle lo dicen ustedes, con este guion.

Estructura

La presentación usa la plantilla de la universidad. Cada sección tiene un color y empieza con una diapositiva separadora del mismo color.

N.º	Diapositiva	Sección	Tiempo
1	Portada	—	0:00–0:15
2	¿Quién decide si puedes abrir un archivo? (separador)	Azul: el problema	0:15–1:15
3	Casi siempre decide una línea de código	Azul: el problema	1:15–2:00
4	Custodia no decide. Le pregunta a Windows. (separador)	Verde: la solución	2:00–2:45
5	Cada operación, con la identidad del usuario	Verde: la solución	2:45–3:50
6	Autenticación: cuatro filtros en orden	Verde: la solución	3:50–4:35
7	Cifrado en reposo: AES-256-GCM	Verde: la solución	4:35–5:30
8	Una bitácora que el auditado no puede tocar	Verde: la solución	5:30–6:15
9	Resultados (separador)	Naranja: resultados	6:15–6:20
10	El riesgo más alto del caso	Naranja: resultados	6:20–7:00
11	Los dos riesgos altos ya tienen control	Naranja: resultados	7:00–7:40
12	Probado sobre Windows real	Naranja: resultados	7:40–8:10
13	Demostración (separador)	Azul oscuro: demostración	8:10–8:15
14	Demostración en vivo	Azul oscuro: demostración	8:15–10:00
15	Lo que todavía falta	Azul oscuro: demostración	10:00–10:30
16	La seguridad que no se puede verificar…	Cierre	10:30–11:15
17	Cierre institucional	Cierre	preguntas

Diapositiva 1. Portada

Sección: — • **Tiempo:** 0:00–0:15



Qué se ve

El logo de la universidad, el nombre del proyecto, Custodia, el subtítulo «Control de acceso real y cifrado de archivos sobre Windows» y los nombres de las dos autoras.

Qué significa

Custodia es una aplicación de escritorio para Windows que guarda archivos de forma segura. Hace tres cosas: deja que Windows decida quién puede abrir cada archivo, cifra los archivos para que no se puedan leer fuera de la aplicación y registra todo lo que pasa.

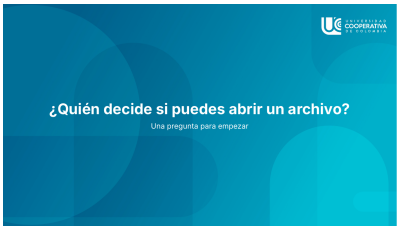
Qué decir

«Buenos días. Somos Dioyanny Aranguren y Paula Quintana, y les vamos a contar cómo construimos Custodia.»

No explicar todavía qué hace Custodia: eso viene después.

Diapositiva 2. ¿Quién decide si puedes abrir un archivo?

Sección: azul, el problema (separador) • **Tiempo:** 0:15–1:15



Qué se ve

Separador azul con la pregunta «¿Quién decide si puedes abrir un archivo?» y el texto «Una pregunta para empezar».

Qué significa

Es la apertura de la charla: un caso real y verificable (unos 40 segundos) que termina en la pregunta. En mayo de 2023, el diario alemán *Handelsblatt* le informó a Tesla que tenía 100 GB de sus archivos internos: unos 23 000 documentos y datos personales de más de 75 000 empleados y exempleados. La investigación de Tesla concluyó que no hubo un ataque externo: dos exempleados que tenían acceso se llevaron los archivos, en violación de las políticas internas (fuente: *Dark Reading*, 21 de agosto de 2023; está en las referencias del informe).

El caso muestra el problema de fondo: los archivos no se pierden solo por hackers, sino porque personas con acceso pueden leerlos y copiarlos sin que nada lo impida ni nadie lo note a tiempo. La charla vuelve a este caso al final.

Qué decir: el caso

«En mayo de 2023, un periódico alemán le escribió a Tesla: tenía cien gigas de sus archivos internos. Veintitrés mil documentos, y datos personales de más de setenta y cinco mil empleados. No hubo hackers. Fueron dos exempleados que tenían acceso y se llevaron los archivos. Nada se lo impidió, y nadie se dio cuenta a tiempo.»

Qué decir: la pregunta

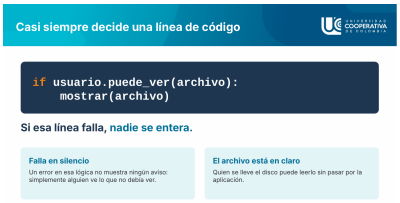
«Por eso les queremos preguntar: ¿quién decide si ustedes pueden abrir un archivo?» Esperar unos segundos. Dejar que alguien responda, o pasar a la siguiente diapositiva.

Si preguntan

¿Tesla usaba Windows? No lo sabemos, y no importa: el caso muestra un problema que tiene cualquier sistema donde las personas con acceso pueden copiar los archivos sin control. Los vacíos concretos de Windows están en la introducción del informe: archivos legibles con la sesión abierta, administrador que puede leerlo todo, auditoría apagada por defecto y ninguna confirmación para copiar o borrar.

Diapositiva 3. Casi siempre decide una línea de código

Sección: azul, el problema • **Tiempo:** 1:15–2:00



Qué se ve

Una línea de código, `if usuario.puede_ver(archivo): mostrar(archivo)`, la frase «Si esa línea falla, nadie se entera» y dos recuadros: «Falla en silencio» y «El archivo está en claro».

Qué significa

Es la respuesta a la pregunta y el problema que motiva el proyecto. En casi todos los sistemas, la decisión de si una persona puede ver un archivo la toma una condición escrita por un programador. Eso tiene dos debilidades:

1. **Falla en silencio.** Si la condición tiene un error, el sistema no avisa: simplemente alguien ve algo que no debía.
2. **El archivo está en claro.** El archivo se guarda tal cual en el disco. Quien saque el disco o copie la carpeta lo lee sin pasar por la aplicación.

Qué decir

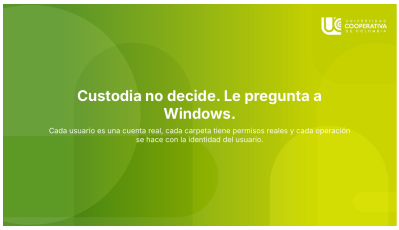
«La respuesta, casi siempre, es una línea de código como esta, que escribió un programador. Si esa línea tiene un error, nadie se entera: no sale ningún aviso, simplemente alguien ve lo que no debía. Y además, el archivo suele estar guardado tal cual en el disco: quien se lleve el disco lo puede leer. Esos son los dos problemas que resuelve Custodia.»

Si preguntan

¿Es eso un problema real? Sí. El control de acceso roto es la primera categoría del OWASP Top 10 de 2021, la lista de los riesgos más comunes en aplicaciones web.

Diapositiva 4. Custodia no decide. Le pregunta a Windows.

Sección: verde, la solución (separador) • **Tiempo:** 2:00–2:45



Qué se ve

Separador verde con la idea central: «Custodia no decide. Le pregunta a Windows.» Debajo: «Cada usuario es una cuenta real, cada carpeta tiene permisos reales y cada operación se hace con la identidad del usuario.»

Qué significa

Es la solución y abre la sección verde, que explica cómo se implementó la seguridad. Custodia no tiene ninguna regla propia para decidir permisos. Cada persona es una cuenta de usuario real de Windows, y cada carpeta tiene permisos reales de Windows (los mismos que se ven en Propiedades >Seguridad). Cuando alguien quiere abrir un archivo, Custodia se pone en los zapatos de esa persona, intenta abrirlo y Windows responde sí o no.

Sobre esa base hay tres capas de seguridad:

- **Windows autoriza**: decide quién puede hacer qué (diapositiva 5).
- **El código del teléfono** protege por si alguien roba la contraseña (diapositiva 6).
- **El cifrado AES-256** protege el archivo por si alguien se lleva el disco (diapositiva 7).

Y la bitácora deja constancia de todo (diapositiva 8).

Qué decir

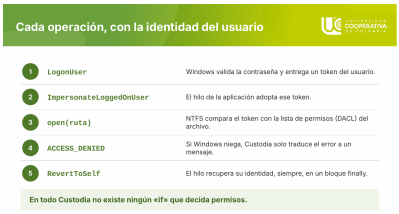
«Custodia no tiene ningún *if* que decida permisos. Lo que hace es ponerse en los zapatos del usuario, intentar la operación, y es Windows el que dice sí o no. Encima de eso hay tres capas: Windows autoriza, el cifrado AES-256 protege por si se llevan el disco, y un código del teléfono confirma por si alguien roba la contraseña. Veamos cómo se implementó cada una.»

Si preguntan

¿Por qué confiar en Windows y no en su propio código? Porque el control de acceso de Windows lleva décadas probándose, lo usa todo el mundo y cualquier administrador puede comprobarlo con sus propias herramientas (`icacls`). Nuestro código sería nuevo y nadie lo habría revisado.

Diapositiva 5. Cada operación, con la identidad del usuario

Sección: verde, la solución • **Tiempo:** 2:45–3:50



Qué se ve

Cinco pasos numerados con nombres de funciones de Windows: `LogonUser`, `ImpersonateLoggedOnUser`, `open(ruta)`, `ACCESS_DENIED` y `RevertToSelf`. Abajo: «En todo Custodia no existe ningún *if* que decida permisos.»

Qué significa

Es el corazón técnico del proyecto: cómo se «pone en los zapatos» del usuario. A esto se le llama **suplantación de identidad** (*impersonation*).

1. `LogonUser`: Custodia le pasa a Windows el usuario y la contraseña. Windows los valida y entrega un **token**, que es como un carné con la identidad de esa persona y sus grupos.
2. `ImpersonateLoggedOnUser`: el hilo de Custodia que hace la operación adopta ese token. Desde ese momento, para Windows es esa persona quien está actuando.
3. `open(ruta)`: se intenta abrir el archivo. El sistema de archivos NTFS compara el token con la lista de permisos del archivo (la DACL).
4. `ACCESS_DENIED`: si la persona no tiene permiso, Windows niega el acceso. Custodia no decide nada: solo traduce ese error a un mensaje.
5. `RevertToSelf`: el hilo vuelve a su identidad original. Se hace siempre, en un bloque `finally`, incluso si hubo un error.

Todo esto ocurre en un solo lugar del programa, la clase `Sesion`, para que un error en otra parte no deje la aplicación con la identidad de otra persona. Además, cada usuario tiene su carpeta personal, que solo él puede ver, y una carpeta compartida con su grupo.

Qué decir

«Este es el corazón técnico. Primero, *LogonUser*: Windows valida la contraseña y nos entrega un token, que es como el carné del usuario. Segundo, *ImpersonateLoggedOnUser*: el hilo de la aplicación adopta ese carné. Tercero, al abrir el archivo, Windows compara el carné con la lista de permisos del archivo. Cuarto, si dice que no, Custodia solo traduce el error. Y quinto, *RevertToSelf* devuelve la identidad original, siempre, en un bloque *finally*. Todo esto pasa en un único lugar del programa, para que un error en un botón no deje la aplicación actuando como otra persona.»

Si preguntan

¿Qué pasa si el programa falla en medio de la operación? El `finally` garantiza que la identidad se devuelve igual. Una prueba comprueba que la identidad se restaura cuando hay errores, y otra que tras 100 operaciones no queda ninguna suplantación activa.

¿Por qué la aplicación se ejecuta como administrador? Porque crea cuentas y cambia permisos. Pero cada operación sobre archivos se hace con la identidad del usuario, no como administrador.

Diapositiva 6. Autenticación: cuatro filtros en orden

Sección: verde, la solución • **Tiempo:** 3:50–4:35



Qué se ve

Cuatro tarjetas numeradas con poco texto: «Bloqueo» (5 fallos: 15 minutos fuera), «Contraseña» (la valida Windows), «Pertenencia» (solo cuentas de Custodia) y «Código del teléfono» (cambia cada 30 segundos). Abajo: «Y el código se vuelve a pedir en cada operación delicada. Cada uno sirve una sola vez.»

Qué significa

Autenticación es comprobar que alguien es quien dice ser. Para entrar a Custodia hay que pasar cuatro filtros, en este orden:

1. **Bloqueo por intentos**: si alguien falla 5 veces en 10 minutos, la cuenta queda bloqueada 15 minutos. Mientras está bloqueada, ni siquiera se consulta a Windows. Esto frena a quien intenta adivinar contraseñas.
2. **Contraseña**: la valida Windows con `LogonUser`. Custodia no guarda ninguna contraseña, así que no hay una base de datos de contraseñas que robar.
3. **Pertenencia**: solo entran las cuentas del grupo `Custodia_Usuarios`. Aunque alguien tenga una cuenta de Windows válida en el equipo, si no está en ese grupo no entra.
4. **Segundo factor**: un código TOTP de 6 dígitos que genera una aplicación del teléfono (como Google Authenticator) y cambia cada 30 segundos.

Además, el código del teléfono se vuelve a pedir para las operaciones delicadas: borrar, sacar copias, cambiar permisos o administrar cuentas. Cada código sirve una sola vez. Así, si alguien deja la sesión abierta, otra persona no puede borrar archivos sin el teléfono.

Qué decir

«Para entrar hay cuatro filtros en orden. Primero, el bloqueo: cinco intentos fallidos bloquean la cuenta quince minutos. Segundo, la contraseña, que la valida Windows; nosotras no guardamos ninguna. Tercero, la cuenta tiene que pertenecer al grupo de Custodia. Y cuarto, el código de seis dígitos del teléfono. Ese código se vuelve a pedir para cada operación delicada, como borrar o sacar una copia, y cada código sirve una sola vez. Así, una sesión olvidada abierta no basta.»

Si preguntan

¿Qué pasa si alguien pierde el teléfono? Un administrador puede restablecer su verificación en dos pasos para que la configure de nuevo.

¿Por qué un bloqueo propio y no el de Windows? Porque fuera de una empresa con dominio, el bloqueo de Windows suele estar desactivado y además no cuenta los códigos del teléfono incorrectos.

Diapositiva 7. Cifrado en reposo: AES-256-GCM

Sección: verde, la solución • **Tiempo:** 4:35–5:30



Qué se ve

Una barra que muestra cómo queda un archivo en el disco: marca `CUSTODIA` (8 bytes), versión (1 byte), tamaño original (8 bytes), nonce (12 bytes) y contenido cifrado con su etiqueta (16 bytes más). Debajo, tres tarjetas cortas («Nonce nuevo», «Detecta cambios», «Clave protegida») y una línea al pie: «Respaldo de la clave en USB · BitLocker comprobado al arrancar».

Qué significa

Cifrado en reposo significa que el archivo se guarda cifrado en el disco: si alguien lo copia por fuera de Custodia, solo ve datos ilegibles. Se usa **AES-256-GCM**, un estándar de cifrado.

- **Nonce nuevo cada vez**: cada vez que se guarda un archivo se genera un número aleatorio de 96 bits. Repetirlo con la misma clave rompería la seguridad de GCM, por eso siempre es nuevo.
- **Detecta manipulación**: GCM añade una etiqueta de 128 bits. Si alguien cambia un solo byte del archivo, la etiqueta no coincide y Custodia rechaza el archivo.
- **Clave protegida**: la clave maestra que cifra todo está protegida con **DPAPI**, el servicio de cifrado de Windows, y solo los administradores y el sistema pueden leer su archivo. Solo está en claro en la memoria mientras la aplicación funciona.

La línea al pie resume dos controles:

- **Respaldo**: si la clave maestra se pierde, se pierden todos los archivos. Por eso un administrador puede exportarla cifrada con una contraseña de recuperación (scrypt + AES-256-GCM) a una USB, en un archivo `.custodiakey`, y restaurarla, incluso en otro equipo. Antes de instalarla, Custodia comprueba que abra los archivos.
- **Robo del disco**: DPAPI usa secretos que están en el mismo equipo, así que quien se lleve el disco completo podría reconstruir la clave. Para eso está BitLocker, que cifra el disco entero. Custodia no puede activarlo, pero al arrancar comprueba si está activo, avisa al administrador y, si se configura, no deja entrar sin él.

Qué decir

«Cada archivo se guarda cifrado con AES-256 en modo GCM. Esta barra es exactamente cómo queda en el disco. Cada vez que se guarda se usa un número aleatorio nuevo, y una etiqueta detecta si alguien cambió un solo byte. La clave maestra la protege DPAPI, el servicio de cifrado de Windows. Si esa clave se perdiera, se perdería todo; por eso se puede exportar cifrada a una USB y restaurar. Y como DPAPI depende del mismo equipo, frente al robo del disco completo Custodia comprueba que BitLocker esté activo.»

Si preguntan

¿Por qué GCM y no otro modo? Porque cifra y a la vez detecta si el archivo fue alterado, en una sola operación.

¿Cuánto cuesta cifrar? Unos 15 milisegundos de sobrecarga en la medición, frente a un límite de 200.

Diapositiva 8. Una bitácora que el auditado no puede tocar

Sección: verde, la solución • **Tiempo:** 5:30–6:15



Qué se ve

Un flujo de cuatro pasos (la operación, se encola, hilo escritor, `audit.db`), los cinco datos de cada registro (quién, cuándo, qué, sobre qué, resultado) y un recuadro corto: «Cadena SHA-256 y anclas en el Visor de eventos».

Qué significa

La **bitácora** es el registro de todo lo que pasa: quién hizo qué, cuándo, sobre qué archivo y si fue permitido o negado. Se guarda en una base de datos SQLite (`audit.db`).

Había un problema de diseño: las operaciones se hacen con la identidad del usuario. Si ese usuario tuviera permiso para escribir en la bitácora, también podría borrar su propio rastro. La solución:

1. La operación solo deja el evento en una cola en memoria, sin tocar el disco.
2. Un hilo aparte, que nunca suplanta a nadie, lo escribe con la identidad de la aplicación.
3. El archivo de la bitácora tiene permisos que excluyen a los usuarios normales.

Contra un administrador del equipo, que sí podría modificar el archivo, se usa el **encadenamiento** propuesto por Schneier y Kelsey: cada registro guarda un resumen SHA-256 del registro anterior. Si alguien edita, borra o inserta un registro, la cadena se rompe. Y cada 50 eventos, y al cerrar, el último resumen se copia al Visor de eventos de Windows (las «anclas»). Si un administrador recalcula toda la cadena, ya no coincide con las anclas. El botón **Verificar integridad** revisa todo esto.

Límite honesto: hace la alteración **evidente**, no imposible. Un administrador que además borre las anclas del Visor de eventos no dejaría diferencia.

Qué decir

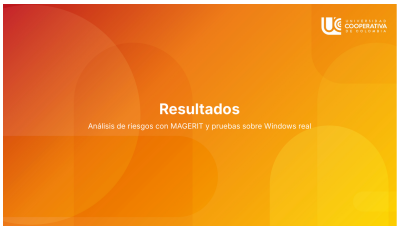
«Si el usuario pudiera escribir la bitácora, podría borrar su propio rastro. Por eso la operación solo encola el evento, y un hilo que nunca suplanta lo escribe con la identidad de la aplicación. Cada registro dice quién, cuándo, qué, sobre qué y con qué resultado, también lo negado. ¿Y si es un administrador? Cada registro guarda el resumen del anterior, y cada cincuenta eventos se copia un ancla al Visor de eventos de Windows. Si alguien edita o borra un registro, el botón Verificar integridad lo detecta.»

Si preguntan

¿Qué es SHA-256? Una función que convierte cualquier dato en una huella de 64 caracteres. Si el dato cambia, aunque sea una letra, la huella cambia por completo.

Diapositiva 9. Resultados

Sección: naranja, resultados (separador) • **Tiempo:** 6:15–6:20



Qué se ve

Separador naranja: «Resultados. Análisis de riesgos con MAGERIT y pruebas sobre Windows real.»

Qué significa

Abre la sección naranja, que responde cómo se sabe que la seguridad funciona: por el análisis de riesgos (diapositivas 10 y 11) y por las pruebas (diapositiva 12).

Qué decir

«¿Cómo sabemos que todo esto funciona? Por dos caminos: el análisis de riesgos y las pruebas.»

Diapositiva 10. El riesgo más alto del caso

Sección: naranja, resultados • **Tiempo:** 6:20–7:00



Qué se ve

A la izquierda, el riesgo «que un usuario lea los archivos de otro», que pasa de 16 (crítico, sin Custodia) a 4 (bajo, con Custodia). A la derecha, una tabla con los 16 riesgos por nivel en tres columnas: sin controles, por defecto y reforzada.

Qué significa

Se hizo un análisis de riesgos con **MAGERIT v3**, la metodología española de análisis de riesgos. Cada riesgo se califica como probabilidad × impacto, cada uno de 1 a 5: de 1 a 4 es bajo, de 5 a 9 medio, de 10 a 15 alto y de 16 a 25 crítico.

- El riesgo más alto era que un usuario leyera archivos de otro: probabilidad $4 \times$ impacto $4 = 16$, crítico. Con Custodia la probabilidad baja a 1, porque la decisión ya no depende de nuestro código sino de Windows: $1 \times 4 = 4$, bajo.
- **Sin controles**: 1 crítico, 11 altos, 4 medios, 0 bajos.
- **Por defecto** (Custodia recién instalada): 0 críticos, 2 altos, 8 medios, 6 bajos.
- **Reforzada**: 0 críticos, 0 altos, 10 medios, 6 bajos. Es la configuración con BitLocker exigido y cifrado por usuario activo.

Qué decir

«Analizamos dieciséis riesgos con la metodología MAGERIT. El más alto era que un usuario leyera archivos de otro: dieciséis, crítico. Con Custodia baja a cuatro, porque ya no depende de nuestro código. Con la configuración por defecto no queda ningún riesgo crítico y quedan dos altos. Con la configuración reforzada no queda ninguno alto. Veamos esos dos.»

Si preguntan

¿Cuántos controles hay? 21, organizados según los modelos AAA (autenticación, autorización, trazabilidad) y CIA (confidencialidad, integridad, disponibilidad). Todos están implementados.

Diapositiva 11. Los dos riesgos altos ya tienen control

Sección: naranja, resultados • **Tiempo:** 7:00–7:40



Qué se ve

Dos tarjetas con capturas reales de Custodia. Izquierda: «R1 · Robo del disco completo», con el aviso «Volumen sin proteger» del perfil del administrador. Derecha: «R6 · Un administrador saca la clave», con la ventana «Crear clave de recuperación». Debajo de cada captura, una frase corta y una franja «Alto → medio».

Qué significa

Son los dos riesgos que siguen altos con la configuración por defecto, y lo que el programa hace contra cada uno:

- **R1, robo del disco completo**. El cifrado de archivos no basta, porque la clave está protegida con secretos del mismo disco. La solución es BitLocker. Custodia no lo puede activar, pero al arrancar consulta a Windows si la unidad del almacén está protegida. Si no lo está, lo registra en la bitácora y muestra el aviso de la captura. Con la opción `CUSTODIA_EXIGIR_BITLOCKER=1`, no deja entrar sin BitLocker. Así R1 baja a medio. La captura es de nuestro propio equipo, que todavía no tiene BitLocker.
- **R6, un administrador saca la clave maestra**. Un administrador del equipo puede pedirle la clave a DPAPI. La solución es el **cifrado por usuario**: cada archivo personal se cifra para las personas que pueden leerlo, así que la clave maestra ya no lo abre. Si alguien olvida su contraseña, perdería sus archivos; para evitarlo hay una **clave de recuperación** que se crea en la ventana de la captura y se guarda en una USB, fuera del equipo. Así R6 baja a medio.

Por defecto ambas cosas están apagadas porque requieren que el administrador haga algo: activar BitLocker y crear la clave de recuperación.

Qué decir

«El robo del disco: Custodia no puede cifrar el disco, pero al arrancar pregunta a Windows si BitLocker está activo, avisa y, si se configura, no deja entrar. Esta captura es de nuestro equipo, que todavía no lo tiene. Y un administrador que saque la clave maestra: con el cifrado por usuario, cada archivo personal se cifra para quien puede leerlo, así que esa clave ya no lo abre. Para no perder archivos si alguien olvida la contraseña, hay una clave de recuperación que se guarda en una USB, no en el equipo.»

Si preguntan

¿Por qué no viene así por defecto? Porque BitLocker depende del equipo y de la edición de Windows, y el cifrado por usuario necesita que alguien cree y guarde la clave de recuperación. Activarlos sin eso podría dejar a alguien sin sus archivos.

Diapositiva 12. Probado sobre Windows real

Sección: naranja, resultados • **Tiempo:** 7:40–8:10



Qué se ve

Cuatro cifras grandes (382 pruebas, 92 % de cobertura, 49 ms, 15 ms) y un recuadro: «Probar contra Windows real encontró dos errores. Las simulaciones no los veían. Los dos se corrigieron.»

Qué significa

- **382 pruebas automatizadas**: 381 pasan y 1 se omite. No usan simulaciones: crean cuentas reales de Windows, ponen permisos reales y los borran al terminar.
- **92 % de cobertura del núcleo**: el 92 % de las líneas del núcleo se ejecutan durante las pruebas. La meta era 80 %.
- **49 ms**: lo que tarda guardar y leer un archivo de 10 MB, con suplantación y cifrado. El límite era 500 ms.
- **15 ms**: lo que añade el cifrado. El límite era 200 ms.

Las pruebas contra Windows real encontraron dos errores que las pruebas simuladas no veían: «quitar de un grupo» fallaba, y la cuenta no quedaba como propietaria de su carpeta. Los dos se corrigieron.

La prueba más importante: una cuenta sin permiso intenta leer un archivo, y la prueba solo pasa si el «no» viene del núcleo de Windows.

Qué decir

«Las pruebas no son simuladas: crean cuentas y permisos reales de Windows. Son 382 y cubren el 92 por ciento del núcleo. Encontraron dos errores reales que las pruebas simuladas no veían, y los dos se corrigieron. Además, la seguridad casi no cuesta: 49 milisegundos por un archivo de 10 megas.»

Diapositiva 13. Demostración

Sección: azul oscuro, demostración (separador)

- **Tiempo:** 8:10–8:15



Qué se ve

Separador azul oscuro: «Demostración. Custodia en vivo.»

Qué significa

Abre la última sección: se deja de explicar y se muestra el programa funcionando.

Qué decir

«Mejor que contarlo, mostrarlo.» Pasar a la aplicación.

Diapositiva 14. Demostración en vivo

Sección: azul oscuro, demostración • **Tiempo:** 8:15–10:00



Qué se ve

Cuatro pasos numerados y una captura de la ventana principal de Custodia, que sirve de respaldo si la demostración falla.

Preparar antes de la charla

- Custodia abierta y dos cuentas de prueba: una estándar y una administradora, ambas con verificación en dos pasos.
- El teléfono con la aplicación de autenticación a mano.
- Un archivo cualquiera en la carpeta personal de la cuenta estándar.

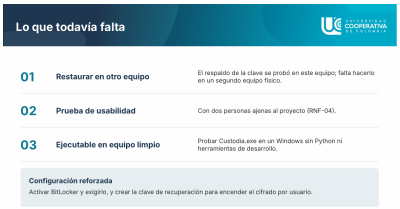
Qué hacer y decir

1. **Entrar** con la cuenta estándar, su contraseña y el código del teléfono. Decir: «Entro con mi contraseña de Windows y el código del teléfono.»
2. **Intentar abrir la carpeta de la otra persona.** Decir: «Intento abrir la carpeta de mi compañera… y Windows dice que no. Custodia no decidió eso.»
3. **Guardar una copia** de un archivo propio. Decir: «Para sacar una copia legible me pide el motivo y otro código. Todo queda registrado.»
4. **Entrar como administradora**, abrir la bitácora y filtrar por **Denegados**. Decir: «Aquí está el intento del paso dos.» Pulsar **Verificar integridad**: «Y la cadena de registros está íntegra.»

Si algo falla, no intentar arreglarlo en vivo: explicar los pasos con la captura de la diapositiva.

Diapositiva 15. Lo que todavía falta

Sección: azul oscuro, demostración • **Tiempo:** 10:00–10:30



Qué se ve

Tres pendientes numerados (01, 02, 03) y un recuadro «Configuración reforzada».

Qué significa

Lo que no se alcanzó a hacer, dicho con honestidad:

1. **Restaurar en otro equipo**: el respaldo de la clave se probó en este computador; falta restaurarlo en un segundo equipo físico.
2. **Prueba de usabilidad**: el requisito RNF-04 pide probar la aplicación con dos personas ajenas al proyecto, y no se ha hecho.
3. **Ejecutable en equipo limpio**: falta probar `Custodia.exe` en un Windows sin Python ni herramientas de desarrollo.

El recuadro es la recomendación para usarla de verdad: activar y exigir BitLocker, y crear la clave de recuperación para encender el cifrado por usuario.

Qué decir

«Queremos ser honestas con lo que falta: probar la restauración del respaldo en otro equipo, hacer la prueba de usabilidad con personas ajenas al proyecto y probar el ejecutable en un equipo limpio. Y para usarlo en serio, recomendamos la configuración reforzada: BitLocker exigido y cifrado por usuario activo.»

Diapositiva 16. La seguridad que no se puede verificar es solo una promesa.

Sección: cierre • **Tiempo:** 10:30–11:15



Qué se ve

La frase final en grande y, debajo, el llamado a la acción: «Antes de confiarle un archivo a un sistema, pregunten quién decide. Y compruébenlo: github.com/yanni2327/custodia». Usa el mismo fondo azul de la pregunta inicial (diapositiva 2), porque responde a esa pregunta.

Qué significa

Es el cierre: un mensaje clave y un llamado a la acción. En la mayoría de sistemas hay que creerle al programador que su código decide bien. En Custodia los permisos son de Windows, cualquiera puede comprobarlos con las herramientas del sistema, y el código está publicado. El llamado a la acción le pide al público dos cosas concretas: preguntar quién decide antes de confiar en un sistema, y comprobar Custodia por sí mismos.

Qué decir

«Al principio les contamos que a Tesla no la atacaron desde afuera: alguien con acceso se llevó los archivos. En Custodia, quien decide no es una línea de código que hay que creerle a alguien: es Windows, cada archivo está cifrado, cada operación pide el teléfono y todo queda registrado. Y cualquiera lo puede comprobar.» Pausa. Decir despacio: «La seguridad que no se puede verificar es solo una promesa.» Luego, el llamado a la acción: «La próxima vez que le confíen un archivo a un sistema, pregunten quién decide. Y no nos crean a nosotras: el código está en GitHub, descárguenlo y compruébenlo. Gracias.»

Diapositiva 17. Cierre institucional

Sección: cierre • **Tiempo:** después de la charla



Qué se ve

La diapositiva de cierre de la Universidad Cooperativa de Colombia.

Qué hacer

Dejarla en pantalla mientras se responden preguntas. Las respuestas probables están en la parte «Si preguntan» de cada diapositiva.

Glosario

AAA y CIA Dos formas de organizar los controles. AAA: autenticación, autorización y trazabilidad. CIA: confidencialidad, integridad y disponibilidad.

ACL / DACL Lista de control de acceso: la lista de permisos de un archivo o carpeta (quién puede leer, modificar, eliminar...). Es lo que se ve en Propiedades >Seguridad.

AES-256-GCM Algoritmo estándar de cifrado con clave de 256 bits. El modo GCM, además de cifrar, detecta si el contenido fue alterado.

Bitácora Registro de auditoría: quién hizo qué, cuándo, sobre qué y con qué resultado.

BitLocker Función de Windows que cifra el disco completo. Protege si alguien se roba el disco o el equipo.

Cifrado por usuario Modo de Custodia en el que cada archivo personal se cifra para las personas que pueden leerlo, de modo que la clave maestra sola no lo abre.

Clave de recuperación Clave que permite devolverle sus archivos a quien olvidó la contraseña cuando el cifrado por usuario está activo. Se guarda en una USB, no en el equipo.

Clave maestra La clave que cifra los archivos en el modo normal. Está protegida con DPAPI y se puede respaldar a una USB.

DPAPI Servicio de Windows que cifra datos con secretos del propio equipo. Custodia lo usa para proteger la clave maestra.

MAGERIT v3 Metodología española de análisis y gestión de riesgos. Riesgo = probabilidad × impacto.

Nonce Número aleatorio que se usa una sola vez en cada cifrado. Nunca debe repetirse con la misma clave.

NTFS El sistema de archivos de Windows. Es el que guarda y aplica los permisos.

RevertToSelf Función de Windows que devuelve al hilo su identidad original después de suplantar.

scrypt Función que convierte una contraseña en una clave de cifrado, diseñada para que adivinar contraseñas sea lento.

SHA-256 Función que genera una huella de 64 caracteres de cualquier dato; si el dato cambia, la huella cambia.

Suplantación (*impersonation*) Hacer que un hilo del programa actúe temporalmente con la identidad de otro usuario.

Token El «carné» que entrega Windows al validar una contraseña: identifica al usuario y sus grupos.

TOTP Código de un solo uso basado en el tiempo (RFC 6238): los 6 dígitos que cambian cada 30 segundos en la aplicación del teléfono.